Network Configuration Review

Standard Operating Procedure

Document Reference: SOP CR 001
Version: 1.0
Status: Active

Document Revision History

Version	Date	Description	Author	Review
1.0	2026	Full restructuring ISO 27001 aligned	Mohamed Yousry, Ahmed El Mohandes	Ahmed Adel

© . *All rights reserved. Unauthorized distribution is prohibited.*

Table of Contents

1 Objective .....

2 Scope .....

3 Roles & Responsibilities .....

4 Definitions .....

5 Prerequisites & Knowledge Baseline .....

6 Tooling Requirements .....

7 Pre Engagement: Client Access Arrangement .....

8 Engagement Execution .....

9 AI Assistance Policy .....

10 Quality Assurance & Report Integrity .....

11 Escalation Protocol .....

12 Remediation Policy .....

13 Follow Up & Retest Policy .....

14 Engagement Duration Reference .....

15 Disclaimer & Client Responsibilities .....

16 Frequently Asked Questions (FAQ) .....

© . All rights reserved. Unauthorized distribution is prohibited.

1. Objective

The purpose of this document is to regulate and standardize the process of Network Configuration Review (Config Review) assessments conducted by the security team. It serves two primary goals:

- To provide all team members involved in configuration review engagements with a clear understanding of what a configuration review entails, how it is structured, and what standards govern it.
- To define the procedural framework from pre engagement preparation through remediation and follow up ensuring consistent, high quality, and compliant delivery across all engagements.

The assessment identifies security weaknesses, misconfigurations, and deviations from vendor recommended hardening guidelines and international standards such as CIS Benchmarks, NIST SP 800 53, and ISO/IEC 27001 controls. It is a non intrusive, evidence based review that does not involve active exploitation of vulnerabilities.

> ℹ **Info:** A configuration review is fundamentally different from a penetration test. It does not involve active attacks or exploitation. It is an audit of device settings, access controls, logging configurations, protocol usage, and policy enforcement.

2. Scope

This Standard Operating Procedure (SOP) applies to all personnel involved in conducting, supervising, or reviewing configuration assessment engagements. The technical scope of a configuration review engagement encompasses the following asset categories:

Asset Category	Examples	Notes
Routers	Cisco ISR, Juniper SRX, MikroTik	Core and edge routing devices
Switches	Cisco Catalyst, HP ProCurve, Aruba	Layer 2/3 switching infrastructure
Firewalls	Palo Alto NGFW, Sophos XG/XGS, Fortinet, Check Point, pfSense	All firewall types and generations
Access Points (APs)	Cisco Meraki, Aruba, Ubiquiti, Ruckus	Wireless infrastructure
VoIP Systems	Cisco UCM, Avaya, 3CX, Asterisk	Voice over IP infrastructure

© . All rights reserved. Unauthorized distribution is prohibited.

Asset Category	Examples	Notes
Out of Scope	Endpoint configurations, cloud workloads (unless specified)	Requires separate SOP

⚠ **Note:** Any assets not listed above must be explicitly agreed upon in the Statement of Work (SOW) before the engagement begins. Testing undeclared or out of scope assets is strictly prohibited.

3. Roles & Responsibilities

All team members participating in a configuration review engagement must understand their roles and adhere to the responsibilities defined below. This structure aligns with ISO/IEC 27001 Annex A controls relating to information security responsibilities.

3.1 Configuration Review Tester

- Must possess a solid foundational and applied understanding of network architecture, protocols, and security principles as detailed in Section 5 of this document.
- Is personally accountable for the accuracy, completeness, and integrity of all findings produced during the engagement.
- Must strictly adhere to all procedures, policies, and restrictions defined in this SOP.
- Must not exceed the agreed scope of the engagement under any circumstances.
- Is responsible for escalating unclear, unusual, or ambiguous findings to a senior expert before classifying them.
- Must document all activities, findings, and decisions throughout the engagement in a clear and traceable manner.

3.2 Senior Security Expert

- Provides technical guidance and serves as the escalation point for complex or unresolved findings.
- Reviews and approves final deliverables before submission to the client.
- Is responsible for the overall technical quality of the engagement output.

© . *All rights reserved. Unauthorized distribution is prohibited.*

3.3 Engagement Manager / Team Lead

- Coordinates pre engagement logistics, client communications, and meeting scheduling.
- Ensure all team members are properly equipped (tools installed, access arranged) before the engagement begins.
- Manages timeline compliance and escalates delivery risks to management.

3.4 Client Point of Contact

- Must be a technically knowledgeable representative authorized to provide access and answer questions about the in scope environment.
- Is responsible for providing complete, accurate, and unmodified configuration data.
- Must disclose all relevant network assets, third party integrations, and infrastructure dependencies within scope.

> ⛔ **Important:** The tester is personally responsible for any finding that is published in the final report. Submitting false positives, duplicates, or unverified findings is a professional violation and may result in disciplinary action.

4. Definitions

The following terms are used throughout this document. Understanding these definitions is mandatory for all team members prior to beginning any engagement.

Term	Definition
Configuration Review	A structured security audit of network device configuration files to identify misconfigurations, security weaknesses, and deviations from hardening baselines without active exploitation.
Configuration File	A file exported from a network device (router, switch, or firewall) that contains the device's current operational settings, access control lists, interface configurations, routing policies, and security parameters.
CIS Benchmark	The Internet Security Benchmark set of consensuses based, vendor endorsed configuration guidelines used as a gold standard for device hardening across routers, firewalls, and switches.
NGFW (Next Generation Firewall)	A firewall that operates at Layer 7 (application layer) and includes features such as deep packet inspection (DPI), intrusion prevention (IPS), application identification, SSL inspection, and user/group based policies.
ACL (Access Control List)	A set of rules on a network device that permits or denies traffic based on defined criteria such as source/destination IP, port, or protocol.

© . *All rights reserved. Unauthorized distribution is prohibited.*

Term	Definition
SNMP (Simple Network Management Protocol)	Protocol is used to monitor and manage network devices. Older versions (v1, v2c) use plaintext community strings for authentication and are considered insecure. SNMPv3 provides encryption and stronger authentication.
RADIUS (Remote Authentication Dial In User Service)	A networking protocol that provides centralized authentication, authorization, and accounting (AAA) for network access. Commonly used for 802.1X port based authentication on switches and wireless networks.
EDR (Endpoint Detection & Response)	Security software deployed on endpoints that monitors, detects, and responds to threats at the device level. Relevant to config review when firewall or switch rules reference EDR agent traffic.
NDR (Network Detection & Response)	A security solution that monitors network traffic flows to detect anomalous or malicious behavior. May appear in switch SPAN/mirror port configurations reviewed during the engagement.
DMZ (Demilitarized Zone)	A network segment isolated from both the internal network and the public internet, used to host services that require limited external exposure. Recommended as a remediation strategy for legacy insecure devices.
Telnet	A legacy remote management protocol that transmits all data including credentials in plaintext. Considered critically insecure and should be replaced with SSH (Secure Shell) wherever possible.
SSH (Secure Shell)	An encrypted remote management protocol that provides secure command line access to network devices. The accepted industry standard replacement for Telnet.
2FA / MFA (Two Factor / Multi Factor Authentication)	An authentication mechanism requiring two or more verification factors (e.g., password + OTP). Recommended as compensation for environments where legacy protocols cannot be immediately replaced.
False Positive	A finding reported by an automated tool or tester that appears to be a vulnerability but is, upon investigation, not a genuine security issue in the context of that specific environment.
True Positive	A finding that has been verified as a genuine security weakness or misconfiguration present in the reviewed configuration.
Hardening Baseline	A predefined set of minimum security configuration requirements for a device type, typically derived from CIS Benchmarks, vendor security guides, NIST SP 800 53, or ISO 27001 controls.
SFOS	Sophos Firewall Operating System the firmware powering Sophos XG/XGS firewalls. Requires dedicated analysis tooling (SFOS Analyzer) in addition to general purpose tools like Titania Nipper.
Statement of Work (SOW)	A formal document agreed upon by both the client that defines the scope, deliverables, timeline, and responsibilities for the engagement.

© . All rights reserved. Unauthorized distribution is prohibited.

5. Prerequisites & Knowledge Baseline

Every team member assigned to a configuration review engagement must satisfy the following prerequisites before the engagement begins. These requirements exist to ensure the quality and credibility of findings and to protect both the client and.

5.1 Core Network Protocol Knowledge

As a minimum, the tester must have working knowledge of the following protocols and understand their typical configuration risks:

- **Web traffic management, access control configurations, clear text HTTP exposure, SSL/TLS version enforcement, and certificate validation.** HTTP/HTTPS
- **File sharing protocols, risks associated with SMBv1 (WannaCry vector), enforcing SMBv3 with encryption, and exposure through firewall rules.** SMB (Server Message Block)
- **Email relay configurations, open relay vulnerabilities, TLS enforcement (STARTTLS), and anti spoofing measures (SPF, DKIM, DMARC).** SMTP
- **Community string exposure (v1/v2c), SNMPv3 authentication and encryption requirements, and management plane access controls.** SNMP
- **The security implications of each, version enforcement (SSHv2), and acceptable key exchange algorithms.** SSH vs. Telnet
- **DNS security configurations, split horizon DNS risks, and DNS based data exfiltration concerns.** DNS
- **Time synchronization security, authentication, and the importance of accurate timestamps for log integrity.** NTP
- **Centralized logging configurations, log forwarding security, and the criticality of log completeness for incident response.** Syslog

5.2 Security Technology Awareness

The tester must be familiar with the following security technologies as they frequently appear in client environments and are referenced in configuration files:

- **Understand how EDR agents communicate and how firewall rules may need to accommodate them.** EDR (Endpoint Detection & Response)
- **Understand SPAN/mirror port configurations on switches and how NDR sensors are deployed.** NDR (Network Detection & Response)
- **Deep knowledge of application layer firewall rule construction, zone based policies, IPS signature management, and SSL inspection implications.** NGFW
- **Intrusion detection/prevention system integration and rule management within firewall configurations.** IDS/IPS

© . All rights reserved. Unauthorized distribution is prohibited.

5.3 Third Party Platform Awareness

Client environments commonly include third party management and monitoring platforms. Their presence may explain certain firewall rules, open ports, or authentication flows. The tester must recognize and correctly interpret configurations related to:

- **Network monitoring agents that require specific port access (e.g., SNMP, TCP 10050) and may appear in ACL rules.** Zabbix / Prometheus / Nagios
- **Authentication infrastructure for 802.1X port security, VPN authentication, and network device login. Rules referencing UDP 1812/1813 should be verified against the RADIUS deployment.** RADIUS Server
- **Centralized password vault, Group Policy enforcement, and LDAP/LDAPS integration with network devices for authentication.** Windows Server / Active Directory
- **Cisco proprietary AAA protocol used for device administration authentication, often alongside RADIUS.** TACACS+

5.4 Vendor Familiarity

Testers should have working familiarity with the configuration syntax and security features of common network device vendors encountered in client environments, including but not limited to: Cisco IOS/NX OS, Palo Alto PAN OS, Sophos SFOS, Fortinet FortiOS, Juniper Junos, and Aruba AOS.

> ℹ **Info:** Testers who lack knowledge of a specific protocol, vendor platform, or configuration directive encountered during an engagement must research it before classifying any related finding and escalate to a senior expert if uncertainty remains.

6. Tooling Requirements

All team members assigned to the engagement must have the required tools installed, licensed, and verified on their workstations before the engagement start date. The engagement lead is responsible for confirming tool readiness during the pre engagement checklist.

6.1 Titania Nipper (Primary Analysis Tool)

- Titania Nipper is the primary tool for automated security analysis of router, switch, and firewall configuration files.
- Supported vendors include Cisco IOS, Cisco ASA, Juniper, Palo Alto, Check Point, Fortinet, and many others.
- The tool must be licensed and updated to the latest available version before each engagement.
- Output reports from Nipper must be used as a baseline all findings require manual tester validation before inclusion in the final report.

© . All rights reserved. Unauthorized distribution is prohibited.

6.2 SFOS Analyzer (Sophos Firewall Engagements Only)

- SFOS Analyzer is an open source tool specifically designed for the analysis of Sophos Firewall OS (SFOS) configuration exports.
- Must be installed and tested for any engagement where a Sophos XG or XGS firewall is in scope.
- Used in conjunction with Titania Nipper not as a replacement.
- Installation instructions and the latest release should be obtained from the official open source project repository.

6.3 Supporting Tools

- A text editor with syntax highlighting (e.g., VS Code) for manual configuration file review.
- A secure, encrypted storage medium or vault for handling client configuration files during the engagement.
- A notetaking and findings management system approved by (e.g., internal ticketing or dedicated reporting platform).

> ✓ **Best Practice:** Run both tools against a sample or test configuration file before the engagement begins to confirm correct installation and output. Never start a live engagement with untested tooling.

7. Pre Engagement: Client Access Arrangement

Establishing a clear, agreed upon method for obtaining the target device configuration is a critical pre engagement step. This must be resolved before any technical work begins.

7.1 Preferred Method Direct Network Access

The preferred approach is for the tester to obtain direct, supervised access to the in scope network device(s) during a pre scheduled meeting with the client.

1. Schedule a dedicated pre engagement access meeting with the client's designated point of contact.
2. Request direct network access to the in scope router(s), switch(es), and/or firewall(s).
3. The tester logs in directly to the device and extracts the running configuration in real time, under client supervision.
4. Confirm that the extracted configuration is the current running configuration not a saved or archived version.
5. Document the extraction timestamp, device hostname, and method used.

> ℹ **Info:** Direct access is preferred because it guarantees the configuration is current, complete, and unmodified. However, many clients are unable or unwilling to grant direct device access, and this is perfectly acceptable. The alternative method below is equally valid and commonly used.

© . All rights reserved. Unauthorized distribution is prohibited.

7.2 Alternative Method Client Provided Configuration File

When the client cannot or chooses not to provide direct device access, the following procedure applies. This is a standard and fully acceptable alternative.

6. Schedule a walkthrough meeting with the client to explain the file extraction process clearly and non technically.
7. Provide the client with written instructions specifying the exact file format required (e.g., .cfg, .conf, .xml, .tar) based on the device vendor and model.
8. Instruct the client to export the configuration exactly as is from the device. No manual editing, renaming, or partial exports.
9. The client must provide the correct, complete filename as generated by the device's export function.
10. Upon receipt, the tester must verify the file is intact, parseable, and corresponds to the correct device before proceeding.
11. Document the file receipt timestamp, filename, hash (MD5/SHA 256), and the client contact who provided it.

> ⚠ **Note:** is not responsible for assessment gaps, inaccuracies, or missed findings that result from an incomplete, modified, or incorrect configuration file provided by the client. All client responsibilities in this regard are covered under Section 15.

8. Engagement Execution

Once access to the configuration has been secured and all prerequisites confirmed, the tester may begin the formal assessment. The following procedural guidelines apply throughout the engagement.

8.1 Creative Problem Solving & Contextual Analysis

Testers are expected to analyze findings in the context of the client's specific environment, not in isolation. Standard tool output must always be interpreted with professional judgment. When an identified weakness cannot be immediately remediated due to technical, operational, or legacy constraints, the tester should propose practical, layered compensating controls.

Example Legacy Devices Supporting Telnet Only:

- Recommend hardware replacement as the primary long term remediation.
- As an interim compensating control: isolate the device in a dedicated DMZ segment.
- Implement two factor authentication (2FA) at the DMZ boundary to compensate for Telnet's lack of encryption.
- Document client risk acceptance formally if the client defers the replacement.

© . *All rights reserved. Unauthorized distribution is prohibited.*

8.2 Third Party & Infrastructure Awareness

Before classifying any finding, the tester must consider whether configurations that appear anomalous are in fact intentional accommodations for known third party platforms in the environment (e.g., monitoring agents, RADIUS authentication, AD integration). Misidentifying intentional configurations as vulnerabilities is a quality failure.

8.3 Reporting & Documentation

- All findings must be documented with title, description, evidence (configuration snippet or reference), risk rating (Critical / High / Medium / Low / Informational), and remediation recommendation.
- Each finding must be unique, verified true positive duplicates and false positives are not acceptable.
- Findings must be cross referenced against applicable standards (CIS Benchmark, NIST SP 800 53, ISO 27001) where relevant.
- The tester must be prepared to explain every finding in the client meeting clearly without reading the report.

9. AI Assistance Policy

We encourage the use of AI language model tools (such as large language models) to support testers in research, analysis, and report writing. Responsible use of AI can significantly improve the depth and clarity of deliverables. However, strict data handling rules apply.

9.1 Permitted Uses

- Researching unfamiliar protocols, configuration directives, or vendor specific syntax.
- Cross referencing hardening recommendations against published standards.
- Assisting with drafting finding descriptions, risk ratings, and remediation recommendations using sanitized, anonymized configuration excerpts only.
- Generating executive summary language or report templates.

9.2 Strictly Prohibited

- Providing any AI tool with client external IP addresses.
- Sharing client access credentials, API keys, or authentication tokens of any kind.
- Inputting private or public cryptographic keys belonging to the client.
- Uploading complete, unmodified client configuration files containing identifying information to any public AI service or cloud based tool.

Important: Violation of the AI data handling rules constitutes a serious data privacy breach that may expose the client to legal and regulatory liability. Any suspected violation must be reported to the team leader and escalated to management immediately.

© . *All rights reserved. Unauthorized distribution is prohibited.*

10. Quality Assurance & Report Integrity

Before any delivery is submitted to the client, the tester and reviewing senior expert must complete the following quality assurance checks. This process aligns with ISO 9001 quality management principles as applied to professional services delivery.

12. Eliminate all duplicate findings the same misconfiguration or weakness must not appear more than once, regardless of how many tools flagged it.
13. Verify each finding as a true positive confirm that the identified issue is a genuine misconfiguration or security weakness in the context of this specific environment, not a tool false positive or miscategorized intentional configuration.
14. Cross reference automated tool output with manual validation for all findings rated High or Critical.
15. Ensure every finding includes: a clear title, a description of the issue and its risk, the specific evidence from the configuration file, a risk rating, and a concrete remediation recommendation.
16. Verify that remediation recommendations are practical and contextualized to the client's environment generic recommendations are not acceptable for high severity findings.
17. Have the report reviewed by a peer or senior expert before client submission if the engagement timeline allows.

> ✓ **Best Practice:** A peer review even an informal one catches significantly more errors than self review alone. Always budget time for it.

11. Escalation Protocol

Testers must not classify or publish findings they do not fully understand. The following escalation procedure is mandatory when a tester encounters an unfamiliar protocol, configuration pattern, or ambiguous scenario.

18. Conduct independent research first review vendor documentation, CIS benchmarks, NIST guidance, or other authoritative sources to understand the configuration in question.
19. If the research does not resolve the ambiguity or uncertainty within a reasonable time, escalate to a senior expert on the team.
20. Document the escalation formally: describe the findings, summarize the research conducted, and explain the reason for escalation.
21. The senior expert's determination is the authoritative classification for that finding. It must be documented and referenced in the report.

© . *All rights reserved. Unauthorized distribution is prohibited.*

22. If the senior expert is also unable to classify the findings, it should be noted in the report as 'Under Review Further Investigation Required' and a timeline for resolution agreed with the client.

> ⚠ **Note:** Escalating a finding is a sign of professional rigor, not a sign of weakness. Publishing an incorrectly classified finding whether overstated or understated is far more damaging than escalating it.

12. Remediation Policy

Following the delivery of the final assessment report, provides structured remediation support to assist the client in addressing identified findings. Remediation is a collaborative process and is governed by this policy.

12.1 Collaboration Model

Remediation should be conducted through active cooperation between the tester (service provider side) and the client's network administrator or designated technical owner. Both parties share responsibility for the outcome of the remediation phase.

12.2 Meeting Based Remediation

- Remediation activities may be conducted over a series of pre scheduled meetings agreed upon by both the client and the client.
- In these sessions, the tester guides the client's network administrator through each finding, explains the recommended fix, and validates that the configuration change achieves the intended security outcome.
- Meeting schedules, attendees, and outcomes must be documented in writing after each session.

12.3 Tester Led Direct Remediation

- Alternatively, the tester may implement remediation changes directly on the client's devices, with the explicit written permission of the client.
- Direct remediation requires a change management agreement signed by the client before any configuration changes are made.
- All changes made directly by the tester must be logged, time tamped, and provided to the client in a change log document upon completion.
- Tester led direct remediation must never be performed without prior written authorization verbal permission is not sufficient.

> ℹ **Info:** Both the meeting based and tester led direct remediation approaches are fully valid and are selected based on the client's preference, internal IT capacity, and the complexity of the findings. There is no universally 'better' method.

© . *All rights reserved. Unauthorized distribution is prohibited.*

12.4 Remediation Priority

Findings should be remediated in order of risk rating:

- Critical and High Immediate action required; remediation plan must be initiated within 5 business days of report delivery.
- Medium Remediation plan to be initiated within 30 calendar days.
- Low and Informational Addressed at the client's discretion during the next scheduled maintenance window.

13. Follow Up & Retest Policy

The engagement does not conclude with report delivery. A structured follow up and retest cycle is a mandatory component of every configuration review engagement and is essential to ensure that remediation efforts have been effective.

13.1 Follow Up Schedule

- The tester must establish a follow up schedule with the client at the time of report delivery. The cadence should be agreed upon by both parties and documented in writing.
- Standard follow up intervals: weekly check ins during active remediation; bi weekly once all critical/high findings have been addressed.
- The tester is responsible for proactively initiating follow up communications the client should not need to chase.

13.2 Retest Requirements

- After the client has completed remediation of a finding (or a batch of findings), the tester must conduct a formal retest to verify that the fix has been correctly implemented and has not introduced new issues.
- The retest scope is limited to the specific remediated findings it is not fully re engaged unless separately scoped and agreed.
- The retest must be performed using the same methodology as the original assessment to ensure a fair and consistent comparison.
- Retest results must be documented in a Retest Report that clearly states finding reference, original status, remediation applied, retest status (Resolved / Partially Resolved / Not Resolved), and tester sign off.

© . *All rights reserved. Unauthorized distribution is prohibited.*

13.3 Closure

- The engagement is formally closed when all Critical and High findings have been verified as Resolved in the Retest Report, or when the client has formally accepted the residual risk in writing for any deferred items.
- A final Closure Letter summarizing the engagement outcomes, remediation status, and any accepted risks is provided to the client at engagement close.

✓ **Best Practice:** A well documented retest and closure process protects us from post engagement liability and provides the client with a clear, auditable record of compliance improvements.

14. Engagement Duration Reference

The following table provides guideline timeframes for configuration review engagements based on device type and configuration complexity. **These are working day estimates for the assessment phase only starting from the client handing off the file and do not include time for report writing, remediation support, or retesting.**

Device / Scope	Min. Days	Max. Days	Key Drivers
Switch Small Config (~2,000 lines)	4	7	VLAN config, ACLs, port security
Switch / Router Medium Config	7	10	Routing protocols, complex ACLs
Firewall Full Config with Filters & Rules	10	15	Heavy rule sets, NAT policies, IPS
Access Points Wireless Infrastructure	14	30	Multi SSID, RADIUS integration, RF policies
VoIP Systems	14	30	Dial plans, SIP security, VLAN segmentation
Multi Device Engagement (mixed scope)	Custom	Custom	Scoped separately per SOW

⚠ **Note:** These estimates assume a single, experienced tester working full time on the engagement. Engagements with multiple in scope devices of the same type should be scoped individually for each device. Access point and VoIP engagements are classified as special case assessments and require senior review before timeline commitment.

© . *All rights reserved. Unauthorized distribution is prohibited.*

15. Disclaimer & Client Responsibilities

Limitation of Liability

Assessment findings and conclusions are bound by the information and access provided by the client. Bears no responsibility for gaps, inaccuracies, or missed findings that result from information withheld or not made available during the engagement.

15.1 Client Obligations

- Provide complete, unmodified configuration files and documentation for all in scope devices.
- Disclose all network assets, third party integrations, and relevant infrastructure dependencies within scope.
- Designate a technically qualified point of contact authorized to answer questions about the in scope environment throughout the engagement.
- Be fully transparent about who is responsible for each in scope device and its configuration.
- Notify of any planned or in progress configuration changes affecting in scope devices during the engagement period.

15.2 Limitation of Scope

Any assets, configurations, or third party systems that were not disclosed or made available during the engagement are explicitly out of scope. Findings, recommendations, and liability are strictly limited to what was reviewed and documented in the agreed Statement of Work.

© . *All rights reserved. Unauthorized distribution is prohibited.*

16. Frequently Asked Questions (FAQ)

The following questions address the most common queries raised by both clients and team members in relation to the configuration review process.

Q1. What is the difference between a configuration review and a penetration test?

A configuration review is a non intrusive audit of device settings, access controls, and policy configurations. It does not involve exploiting vulnerabilities. A penetration test actively attempts to exploit weaknesses to demonstrate real world impact. Both are complementary. A config review often identifies the misconfigurations that a penetration test would subsequently exploit.

Q2. Why does the tester need direct access to our device? Can they just work with the config file?

Direct access is preferred because it guarantees the configuration reflects the actual running state of the device, which can differ from saved or archived versions. However, providing a configuration file is fully acceptable and commonly done. The key requirement is that the file is complete, unmodified, and represents the current device state.

Q3. We are not comfortable giving direct access to our production network devices. What are our options?

This is a common and completely valid concern. In this case, your designated technical contact can export the configuration file directly from the device and provide it to the tester. Will provide clear written instructions for how to do this for your specific device model. The tester will work exclusively from the exported file.

Q4. How long will the assessment take?

Duration depends on the device type and configuration complexity. A small switch configuration may take as few as 4 working days, while a complex firewall with extensive rule sets may take up to 15 days. Access point and VoIP system reviews can take up to 30 days. A formal timeline estimate will be provided in the Statement of Work before the engagement begins.

Q5. Will share our configuration files with any third parties or AI tools?

No.testers are explicitly prohibited from uploading complete client configuration files to any AI tool, cloud service, or external platform. AI tools may only be used with fully anonymized and sanitized excerpts. Configuration files are handled and stored encrypted, access controlled internal systems only.

© . All rights reserved. Unauthorized distribution is prohibited.

Q6. What happens after the report is delivered? Is the engagement over?

No. Report delivery marks the beginning of the remediation phase. Will work with your network administrator through a series of pre agreed meetings or by directly implementing fixes with your permission. After remediation, we will conduct a formal retest to verify that all findings have been correctly addressed before closing the engagement.

Q7. What if our devices are very old and some security recommendations are not technically feasible?

This is a real and common situation. Testers are expected to propose practical compensating controls for legacy environments for example, isolating insecure devices in a DMZ with additional authentication layers. Every high severity finding will include both an ideal remediation and a realistic interim option. Formally accepted residual risks will be documented in the closure report.

Q8. Can we ask the tester to explain the findings in a language a non technical person can understand?

Yes, and this is expected. Testers are required to prepare for client meetings with the ability to explain every finding in plain language without technical jargon. If your organization requires an executive briefing separate from the technical debrief, please inform your engagement manager when scheduling the report delivery meeting.

Q9. What if we have third party software like Zabbix or a RADIUS server that the tester might misidentify as a misconfiguration?

This is why full disclosure of your environment is critical. Before the assessment begins, please inform of all third party monitoring, authentication, and management platforms in use. Testers are trained to recognize common platforms and will validate any finding that could relate to a known third party integration before classifying it.

Q10.What standards does configuration review process align with?

's configuration review methodology is aligned with CIS Benchmarks (vendor specific hardening guidelines), NIST SP 800 53 (Security and Privacy Controls for Information Systems), and ISO/IEC 27001 Annex A controls particularly those relating to network security management, access control, and configuration management. Where applicable, vendor specific security guides are also referenced.

End of Document

Document Reference: SOP CR 001 | Version 1.0

© . All rights reserved. Unauthorized distribution is prohibited.